

Seguridad en redes

- 21.1. Requisitos de seguridad y ataques**
 - Ataques pasivos
 - Ataques activos
- 21.2. Privacidad con cifrado simétrico**
 - Cifrado simétrico
 - Algoritmos de cifrado
 - Localización de los dispositivos de cifrado
 - Distribución de claves
 - Relleno de tráfico
- 21.3. Autenticación de mensajes y funciones de dispersión (*hash*)**
 - Alternativas para la autenticación de mensajes
 - Funciones de dispersión seguras
 - La función de dispersión segura SHA-1
- 21.4. Cifrado de clave pública y firmas digitales**
 - Cifrado de clave pública
 - Firma digital
 - El algoritmo de cifrado de clave pública RSA
 - Gestión de claves
- 21.5. Capa de *sockets* segura (SSL) y capa de transporte segura (TLS)**
 - Arquitectura SSL
 - Protocolo de registro de SSL
 - Protocolo de cambio de especificación de cifrado
 - Protocolo de alerta
 - Protocolo de negociación bilateral
- 21.6. Seguridad en IPv4 e IPv6**
 - Aplicaciones de IPSec
 - Ámbito de IPSec
 - Asociaciones de seguridad
 - Cabecera de autenticación
 - Encapsulado de la carga útil de seguridad
- 21.7. Lecturas y sitios web recomendados**
- 21.8. Términos clave, cuestiones de repaso y ejercicios**
 - Términos clave
 - Cuestiones de repaso
 - Ejercicios

-

Los requisitos de la **seguridad de la información** dentro de una organización han sufrido dos cambios principales en las últimas décadas. Antes de que se extendiera la utilización de los equipos de procesamiento de datos, la seguridad de la información valiosa para la organización se proporcionaba fundamentalmente por medios físicos y administrativos. Como ejemplo del primer tipo de medios sirva el empleo de robustos archivadores con cerrojo de combinación para almacenar los documentos importantes. Un ejemplo del segundo es el uso de procedimientos de investigación del personal durante el proceso de contratación.

Con la introducción de los computadores, se hizo evidente la necesidad de herramientas automáticas para proteger ficheros y otra información almacenada en el computador. Éste es especialmente el caso de los sistemas compartidos, como los sistemas multiusuario. Esta necesidad se acentúa en los sistemas a los que se pueda acceder desde redes de datos o redes de telefonía públicas. El término genérico del conjunto de herramientas diseñadas para proteger los datos y frustrar las actividades de los piratas de la computación es **seguridad en computadores**. Aunque constituye un tema muy importante, se encuentra fuera del alcance de este libro.

El segundo cambio relevante que ha afectado a la seguridad es la introducción de sistemas distribuidos y la utilización de redes y servicios de comunicación para transportar datos entre terminales de usuario y computadores y de computador a computador. Las medidas de **seguridad en red** son necesarias para proteger los datos durante su transmisión y garantizar que los datos transmitidos sean auténticos.

La tecnología esencial subyacente, virtualmente, en todas las aplicaciones de seguridad en redes y computadores es el cifrado. Se utilizan dos técnicas fundamentales: cifrado simétrico y

cifrado de clave pública, también conocido como cifrado asimétrico. Conforme examinemos las diversas técnicas de seguridad en red, iremos explorando los dos tipos de cifrado.

Este capítulo comienza con una visión global de los requisitos de seguridad en red. A continuación, se examinará el cifrado simétrico y su utilización para proporcionar privacidad. A esto le sigue una discusión sobre la autenticación de mensajes. Se examinará el uso del cifrado de clave pública y las firmas digitales. El capítulo termina con un estudio de las características de seguridad de SSL e IPsec.

21.1. REQUISITOS DE SEGURIDAD Y ATAQUES

Para entender los tipos de amenazas a la seguridad que existen, necesitamos partir de una definición de requisitos en seguridad. La seguridad en computadores y en redes implica cuatro requisitos:

- **Privacidad:** se requiere que sólo entidades autorizadas puedan tener un acceso a la información. Este tipo de acceso incluye la impresión, la visualización y otras formas de revelado, incluyendo el simple hecho de dar a conocer la existencia de un objeto.
- **Integridad:** se requiere que los datos sean modificados solamente por partes autorizadas. La modificación incluye la escritura, la modificación, la modificación del estado, la supresión y la creación.
- **Disponibilidad:** se requiere que los datos estén disponibles para las partes autorizadas.
- **Autenticidad:** se requiere que un computador o servicio sea capaz de verificar la identidad de un usuario.

Una forma útil de clasificar los ataques a la seguridad (RFC 2828) es en términos de *ataques pasivos* y *ataques activos*. Un ataque pasivo intenta averiguar o hacer uso de información del sistema, pero sin afectar a los recursos del mismo. Un ataque activo intenta alterar los recursos del sistema o influir en su funcionamiento.

ATAQUES PASIVOS

Los ataques pasivos consisten en escuchas o monitorizaciones de las transmisiones. La meta del oponente es la de obtener la información que está siendo transmitida. La divulgación del contenido de un mensaje y el análisis de tráfico constituyen dos tipos de ataques pasivos.

La **divulgación del contenido de un mensaje** se entiende fácilmente. Una conversación telefónica, un mensaje de correo electrónico o un fichero transferido pueden contener información sensible o confidencial. Por ello, deseáramos impedir que un oponente averigüe el contenido de estas transmisiones.

Un segundo tipo de ataque pasivo, el **análisis de tráfico**, es más sutil. Suponga que disponemos de un medio para enmascarar el contenido de los mensajes u otro tipo de tráfico de información, de forma que aunque los oponentes capturasen el mensaje, no podrían extraer la información del mismo. La técnica más común para enmascarar el contenido es el cifrado. Pero incluso si tenemos protección por cifrado, el oponente podría todavía observar el patrón de estos mensajes. El oponente podría determinar la localización y la identidad de los computadores que se están comunicando y observar la frecuencia y la longitud de los mensajes intercambiados. Esta información podría serle útil para averiguar la naturaleza de la comunicación que se está realizando.

Los ataques pasivos son muy difíciles de detectar, ya que no suponen la alteración de los datos. Normalmente, el tráfico de mensajes es enviado y recibido de forma aparentemente normal y ni el emisor ni el receptor son conscientes de que un tercero haya leído los mensajes u observado el patrón de tráfico. Sin embargo, es factible impedir el éxito de estos ataques, usualmente mediante cifrado. De esta manera, el énfasis en la defensa contra estos ataques se centra en la prevención en lugar de en la detección.

ATAQUES ACTIVOS

Los ataques activos suponen alguna modificación del flujo de datos o la creación de flujos falsos. Los podemos clasificar en 4 categorías: enmascaramiento, retransmisión, modificación de mensajes y denegación de servicio.

Un **enmascaramiento** tiene lugar cuando una entidad pretende ser otra entidad diferente. Un ataque por enmascaramiento normalmente incluye una de las otras formas de ataques activos. Por ejemplo, se pueden capturar secuencias de autenticación y retransmitirlas después de que tenga lugar una secuencia válida, permitiendo así obtener privilegios adicionales a otra entidad autorizada con escasos privilegios mediante la suplantación de la entidad que los posee.

La **retransmisión** supone la captura pasiva de unidades de datos y su retransmisión posterior para producir un efecto no autorizado.

La **modificación de mensajes** significa sencillamente que algún fragmento de un mensaje legítimo se modifica o que el mensaje se retrasa o se reordena para producir un efecto no autorizado. Por ejemplo, un mensaje con un significado «Permitir a Juan García leer el fichero confidencial de cuentas» se modifica para tener el significado «Permitir a Alfredo Castaño leer el fichero confidencial de cuentas»

La **denegación de servicio** impide o inhibe el normal uso o gestión de servicios de comunicación. Este ataque puede tener un objetivo específico. Por ejemplo, una entidad puede suprimir todos los mensajes dirigidos a un destino concreto (por ejemplo, al servicio de vigilancia de seguridad). Otro tipo de denegación de servicio es la interrupción de un servidor o de toda una red, bien deshabilitando el servidor o sobrecargándolo con mensajes con objeto de degradar su rendimiento.

Los ataques activos presentan características opuestas a las de los ataques pasivos. Mientras que un ataque pasivo es difícil de detectar, existen medidas para impedir que tengan éxito. Por otro lado, es bastante difícil impedir ataques activos de forma absoluta, ya que para hacerlo se requeriría protección física permanente de todos los recursos y de todas las rutas de comunicación. En su lugar, el objetivo consiste en detectarlos y recuperarse de cualquier interrupción o retardo causados por ellos. Ya que la detección tiene un efecto disuasorio, también puede contribuir a la prevención.

21.2. PRIVACIDAD CON CIFRADO SIMÉTRICO

La técnica universal para proporcionar privacidad en los datos transmitidos es el cifrado simétrico. Esta sección examina primero los conceptos básicos del cifrado simétrico y sigue con una discusión sobre las dos técnicas de cifrado simétrico más importantes: el estándar de cifrado de datos (DES, *Data Encryption Standard*) y el estándar de cifrado avanzado (AES, *Advanced Encryption Standard*). Después se examinará la aplicación de estas técnicas para lograr la privacidad.

CIFRADO SIMÉTRICO

El cifrado simétrico, también denominado cifrado convencional o de clave única, era el único tipo de cifrado en uso antes de la introducción del cifrado de clave pública a finales de la década de los setenta. Innumerables individuos y grupos, desde Julio César, pasando por la fuerza alemana U-boat, hasta los actuales usuarios diplomáticos, militares y comerciales, han empleado el cifrado simétrico para la comunicación secreta. De los dos tipos de cifrado, es todavía el más utilizado.

Un esquema de cifrado simétrico tiene cinco ingredientes (véase Figura 21.1):

- **Texto nativo (*plaintext*):** es el mensaje original o datos que se proporcionan como entrada del algoritmo.
- **Algoritmo de cifrado:** el algoritmo de cifrado lleva a cabo varias sustituciones y transformaciones sobre el texto nativo.
- **Clave secreta:** la clave secreta es también una entrada del algoritmo de cifrado. Las sustituciones y transformaciones concretas realizadas por el algoritmo dependen de la clave.
- **Texto cifrado (*ciphertext*):** es el mensaje alterado que se produce como salida. Depende del texto nativo y de la clave secreta. Para un mensaje dado, dos claves diferentes producen dos textos cifrados diferentes.
- **Algoritmo de descifrado:** es esencialmente el algoritmo de cifrado ejecutado a la inversa. Toma como entradas el texto cifrado y la clave secreta y produce como salida el texto nativo original.

Existen dos requisitos para la utilización segura del cifrado simétrico:

1. Se necesita un algoritmo de cifrado robusto. Como mínimo, es de desear que el algoritmo cumpla que aunque un oponente conozca el algoritmo y tenga acceso a uno o más textos cifrados, sea incapaz de descifrar el texto o averiguar la clave. Este requisito se suele enunciar de una forma más estricta: el oponente debería ser incapaz de descifrar el texto o descubrir la clave incluso si él o ella poseyera varios textos cifrados junto a sus correspondientes textos nativos.
2. El emisor y el receptor tienen que haber obtenido las copias de la clave secreta de una forma segura y deben mantenerla en secreto. Si alguien puede descubrir la clave y conoce el algoritmo, toda comunicación que utilice esta clave puede ser leída.

Existen dos enfoques generales para atacar el esquema de cifrado simétrico. El primer ataque se conoce como **criptoanálisis**. Los ataques de criptoanálisis se basan en la naturaleza del algoritmo

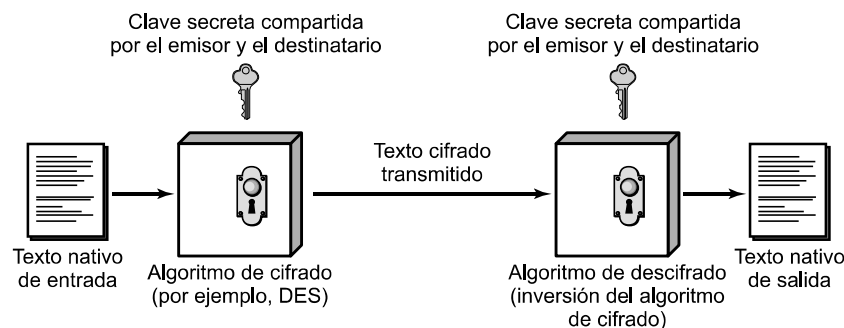


Figura 21.1. Modelo simplificado de cifrado simétrico.

junto a algún posible conocimiento de las características generales del texto nativo o incluso de algunos pares de texto nativo y cifrado. Este tipo de ataque explota las características del algoritmo para intentar deducir un texto nativo concreto o deducir la clave que se esté utilizando. Si el ataque tiene éxito en la deducción de la clave, el efecto es catastrófico: todos los mensajes cifrados con esa clave, pasados y futuros, están comprometidos.

El segundo método, conocido como ataque por **fuerza bruta**, consiste en probar cada posible clave sobre un fragmento de texto cifrado hasta que se obtenga una traducción inteligible de texto nativo. La Tabla 21.1 muestra la cantidad de tiempo que necesita este ataque frente a varias longitudes de clave. La tabla muestra los resultados para cada tamaño de clave, suponiendo que se tarda 1 μ s en llevar a cabo un único descifrado, un orden de magnitud razonable para los computadores actuales. Con el uso de una masiva organización paralela de microprocesadores sería posible alcanzar tasas de procesamiento de varios órdenes de magnitud superiores. La última columna de la tabla considera los resultados de un sistema que pudiera procesar 1 millón de claves por microsegundo. Como se puede ver, a este nivel de rendimiento ya no se puede considerar segura en términos computacionales una clave de 56 bits.

Tabla 21.1. Tiempo promedio necesario para una búsqueda de clave exhaustiva

Tamaño de la clave (bits)	Número de claves alternativas	Tiempo necesario a 1 cifrado/ μ s	Tiempo necesario a 10^6 cifrados/ μ s
32	$2^{32} = 4,3 \times 10^9$	$2^{31} \mu$ s = 35,8 minutos	2,15 milisegundos
56	$2^{56} = 7,2 \times 10^{16}$	$2^{55} \mu$ s = 1.142 años	10,01 horas
128	$2^{128} = 3,4 \times 10^{38}$	$2^{127} \mu$ s = $5,4 \times 10^{24}$ años	$5,4 \times 10^{18}$ años
168	$2^{168} = 3,7 \times 10^{50}$	$2^{167} \mu$ s = $5,9 \times 10^{36}$ años	$5,9 \times 10^{30}$ años

ALGORITMOS DE CIFRADO

Los algoritmos de cifrado simétrico más comúnmente empleados son los cifradores de bloque. Un cifrador de bloque procesa una entrada de texto nativo en bloques de tamaño fijo y produce un bloque de texto cifrado de igual tamaño por cada bloque de texto nativo. Los dos algoritmos simétricos más importantes, ambos cifradores de bloque, son el estándar de cifrado de datos (DES) y el estándar avanzado de cifrado (AES).

El estándar de cifrado de datos (DES)

DES ha constituido el algoritmo de cifrado dominante desde su introducción en 1977. Sin embargo, dado que DES emplea sólo una clave de 56 bits, fue sólo una cuestión de tiempo que la velocidad de procesamiento computacional dejara a DES obsoleto. En 1998, la Fundación de la Frontera Electrónica (EFF, *Electronic Frontier Foundation*) anunció que había roto un reto de DES empleando una máquina de propósito específico para forzar DES, construida por menos de 250.000 dólares. El ataque duró menos de tres días. La EFF ha publicado una descripción detallada de la máquina, permitiendo que otros construyan su propio saboteador [EFF98]. Por supuesto, los precios del hardware continuarán cayendo al mismo tiempo que la velocidad de procesamiento irá aumentando, haciendo de DES un algoritmo inútil.

La vida de DES fue prolongada gracias al uso de triple DES (3DES), que supone la repetición del algoritmo básico DES tres veces, utilizando dos o tres claves únicas, para una longitud de clave de 112 o 168 bits.

El principal inconveniente de 3DES consiste en que el algoritmo por software es relativamente lento. Un inconveniente secundario es que tanto DES como 3DES utilizan un tamaño de bloque de 64 bits. Por razones de eficiencia y de seguridad, es deseable emplear bloques de mayor longitud.

